Entry Information

ID:
AML.CS0008

Type:
Case-Study

Name:
ProofPoint Evasion

URL:
https://atlas.mitre.org/studies/AML.CS0008/

Incident Date:
2019-09-09

Target:
ProofPoint Email Protection System

Actor:
Researchers at Silent Break Security

Description

Proof Pudding (CVE-2019-20634) is a code repository that describes how ML researchers evaded ProofPoint's email protection system by first building a copy-cat email protection ML model, and using the insights to bypass the live system. More specifically, the insights allowed researchers to craft malicious emails that received preferable scores, going undetected by the system. Each word in an email is scored numerically based on multiple variables and if the overall score of the email is too low, ProofPoint will output an error, labeling it as SPAM.

Attack Procedure:
[AML.T0063] Discover AI Model Outputs: The researchers discovered that ProofPoint's Email Protection left model output scores in email headers.
[AML.T0047] AI-Enabled Product or Service: The researchers sent many emails through the system to collect model outputs from the headers.
[AML.T0005.001] Train Proxy via Replication: The researchers used the emails and collected scores as a dataset, which they used to train a functional copy of the ProofPoint model.

Basic correlation was used to decide which score variable speaks generally about the security of an email. The "mlxlogscore" was selected in this case due to its relationship with spam, phish, and core mlx and was used as the label. Each "mlxlogscore" was generally between 1 and 999 (higher score = safer sample). Training was performed using an Artificial Neural Network (ANN) and Bag of Words tokenizing.
[AML.T0043.002] Black-Box Transfer: Next, the ML researchers algorithmically found samples from this "offline" proxy model that helped give desired insight into its behavior and influential variables.

Examples of good scoring samples include "calculation", "asset", and "tyson".
Examples of bad scoring samples include "software", "99", and "unsub".
[AML.T0015] Evade AI Model: Finally, these insights from the "offline" proxy model allowed the researchers to create malicious emails that received preferable scores from the real ProofPoint email protection system, hence bypassing it.

References

- National Vulnerability Database entry for CVE-2019-20634 — https://nvd.nist.gov/vuln/detail/CVE-2019-20634

- 2019 DerbyCon presentation "42: The answer to life, the universe, and everything offensive security" — https://github.com/moohax/Talks/blob/master/slides/DerbyCon19.pdf

- Proof Pudding (CVE-2019-20634) Implementation on GitHub — https://github.com/moohax/Proof-Pudding

- 2019 DerbyCon video presentation "42: The answer to life, the universe, and everything offensive security" — https://www.youtube.com/watch?v=CsvkYoxtexQ&ab-channel=AdrianCrenshaw